

# Week 2: Vulnerability Assessment

## Vulnerability Scan & Risk Report

*Cyber Security — Batch 9.145*

### 1. Scope & Objective

This assessment performs a comprehensive vulnerability scan against the target system used in Week 1 (Metasploitable2), using an automated scanner to identify outdated components, misconfigurations, and insecure credentials, then cross-references findings against CVE and vendor advisories where a published CVE exists.

This scan was conducted unauthenticated and from an external network perspective; it does not evaluate local privilege-escalation paths, host-based misconfigurations, or issues only visible with valid credentials, so results should be read as an outside-attacker's view rather than a full internal audit.

|                     |                                                     |
|---------------------|-----------------------------------------------------|
| Target              | 192.168.56.102 (Metasploitable2, Host-only network) |
| Scanner             | Tenable Nessus Essentials                           |
| Scan policy         | Basic Network Scan                                  |
| Authentication      | Unauthenticated / external black-box scan           |
| Scan duration       | 19 minutes                                          |
| Total findings      | 70 (4 Critical, 3+ High, remainder Medium/Low/Info) |
| Host OS (confirmed) | Linux Kernel 2.6 on Ubuntu 8.04 (hardy)             |

### 2. Scanner Setup

- Installed Nessus Essentials and registered for an activation code.
- Created a new scan using the "Basic Network Scan" template.
- Set target to 192.168.56.102 (the same host scanned with Nmap/Wireshark in Week 1).
- Ran the scan on demand and allowed it to complete fully (19 minutes elapsed).

### 3. Findings — Severity & Verified References

Findings are sorted by severity. Where Nessus's own plugin behaviorally confirmed the flaw (rather than a version match), this is noted as "no CVE" — these are still valid, high-confidence findings, just not tied to one specific published bug.

| Severity | CVSS       | CVE / Ref                      | Finding & Evidence                                                                                                                                                                             |
|----------|------------|--------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Critical | 9.8 / 10.0 | Plugin 51988 (no CVE)          | Bind Shell Backdoor — unauthenticated root shell on port 1524. Nessus executed "id" remotely and received uid=0(root), gid=0(root) — confirmed live root compromise.                           |
| Critical | 9.8 / 10.0 | POODLE-related (CVE-2014-3566) | SSL Version 2 and 3 Protocol Detection — server accepts SSLv2 (40-bit export ciphers on port 25) and SSLv3 (3DES ciphers on port 5432). NIST/PCI DSS prohibit SSLv3 for secure communications. |

| Severity | CVSS | CVE / Ref                  | Finding & Evidence                                                                                                                                                                                        |
|----------|------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Critical | 10.0 | Plugin 201352 (vendor EOL) | Canonical Ubuntu Linux SEoL (8.04.x) — OS reached Security End-of-Life on May 9, 2013 (over 13 years ago). No vendor patches are or will be released.                                                     |
| Critical | 10.0 | Plugin 61708 (no CVE)      | VNC Server 'password' Password — Nessus successfully logged into the VNC service using the password "password". Marked "Exploited by Nessus: true" and "Default Account: true".                           |
| High     | 8.6  | CVE-2020-8616              | ISC BIND Service Downgrade / Reflected DoS — installed version 9.4.2 vs. fixed version 9.11.19. Allows an unauthenticated attacker to degrade the DNS service or use it as a reflection-attack amplifier. |
| High     | 7.5  | Plugin 42256               | NFS Shares World Readable — NFS export has no access restrictions by hostname, IP, or IP range; any host on the network can read the share.                                                               |
| High     | 7.5  | Plugin 10205               | rlogin Service Detection — cleartext login protocol vulnerable to sniffing, spoofing, and TCP sequence-guessing. Marked "Exploit Available: true" — public exploits exist for this service.               |
| High     | 7.5  | SWEET32 (sweet32.info)     | SSL Medium Strength Cipher Suites (SWEET32) — server supports 3DES/64-bit ciphers vulnerable to birthday-attack style plaintext recovery over long sessions.                                              |

## 4. Risk Analysis

### What an attacker could actually do

- Connect directly to port 1524 and receive a root shell with zero authentication — full system takeover in one step.
- Log into the VNC remote-desktop service using the trivial password "password" — full graphical control of the machine.
- Downgrade or intercept encrypted sessions on ports 25 and 5432 by forcing SSLv2/SSLv3, then decrypt or tamper with traffic.
- Read the entire contents of unrestricted NFS shares without any credentials.
- Use the outdated BIND DNS server (CVE-2020-8616) as a reflector in a Distributed Denial-of-Service attack against a third party.
- Rely on publicly available exploit tooling for the rlogin service to intercept credentials or hijack sessions.

### Why severity is compounded here

Because the underlying OS (Ubuntu 8.04) has been unsupported for over 13 years, none of these issues can be resolved through standard patching — the entire platform requires replacement, not incremental fixes.

## 5. Mitigation Recommendations

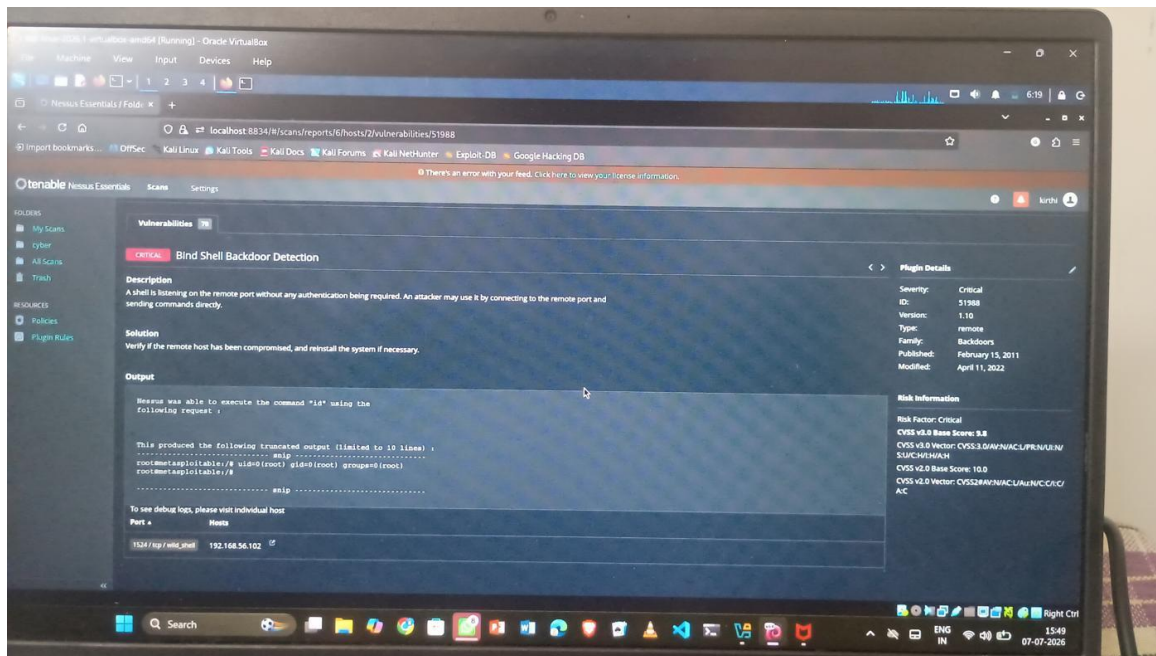
| Finding                         | Recommended Action                                                                                                                               |
|---------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Bind shell backdoor (port 1524) | Close the port immediately; audit the host for signs of prior compromise before any reuse.                                                       |
| Weak/default VNC password       | Set a strong, unique password immediately; consider disabling VNC in favor of an encrypted alternative (e.g. SSH tunnel + VNC, or RDP with NLA). |
| SSLv2/SSLv3 support             | Disable SSLv2 and SSLv3 entirely; enforce TLS 1.2 or higher with approved cipher suites.                                                         |
| End-of-life OS                  | Plan and execute a migration to a currently supported Ubuntu LTS release or equivalent.                                                          |
| Outdated BIND (CVE-2020-8616)   | Upgrade ISC BIND from 9.4.2 to 9.11.19 or later.                                                                                                 |
| World-readable NFS shares       | Restrict NFS exports to specific trusted hosts/IP ranges; remove wildcard access.                                                                |
| rlogin service                  | Disable rlogin entirely; use SSH for all remote administrative access.                                                                           |
| SWEET32 / weak ciphers          | Remove 3DES and other medium-strength ciphers from the server's supported cipher list.                                                           |

## 6. Conclusion

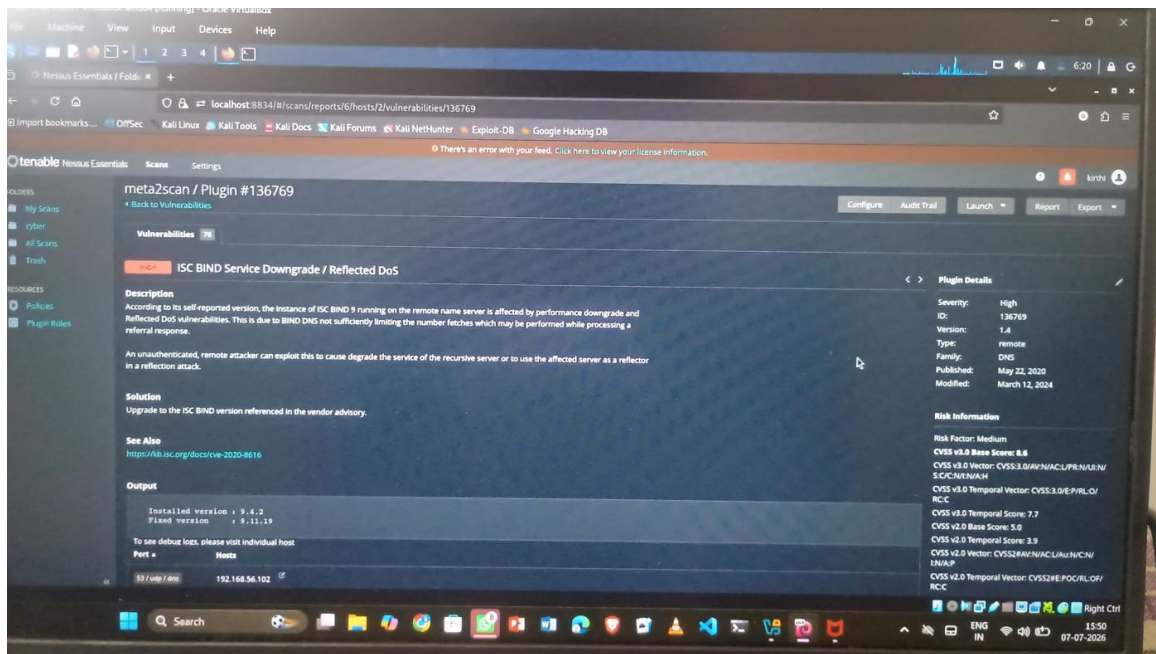
This vulnerability assessment confirmed 4 Critical and multiple High-severity issues on the target host, several of which were not just detected but actively exploited during the scan itself (root shell access and VNC login). The combination of an end-of-life operating system, an unauthenticated backdoor, and trivially weak credentials represents a near-total compromise scenario requiring no advanced attacker skill. Remediation should prioritize closing the bind-shell port and securing VNC access immediately, followed by a full OS migration plan, since patching individual services cannot fully resolve the risk posed by an unsupported underlying platform.

## Appendix: Evidence Screenshots

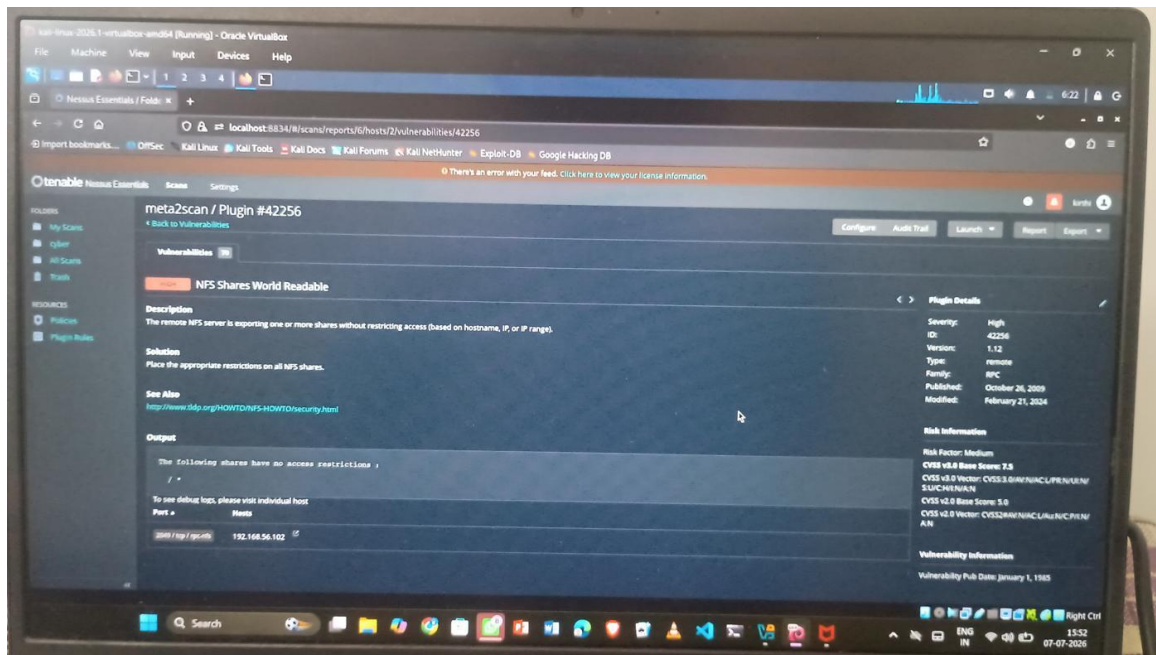
### A1. Bind Shell Backdoor — Live Root Access Confirmed



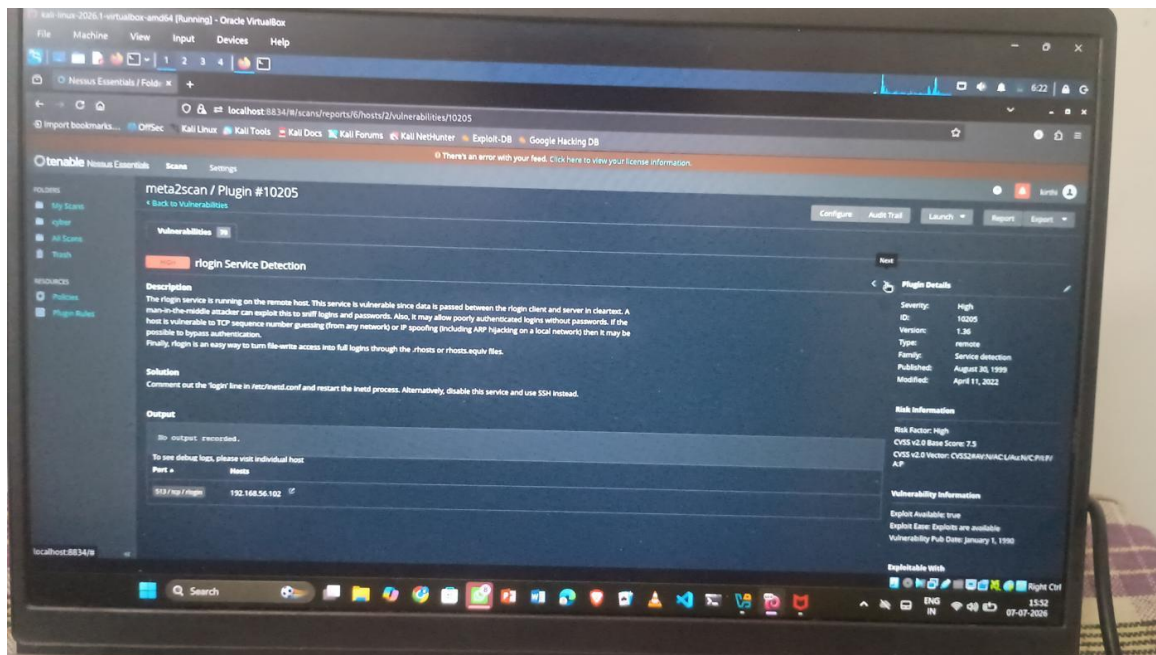
### A2. ISC BIND Downgrade/DoS — CVE-2020-8616



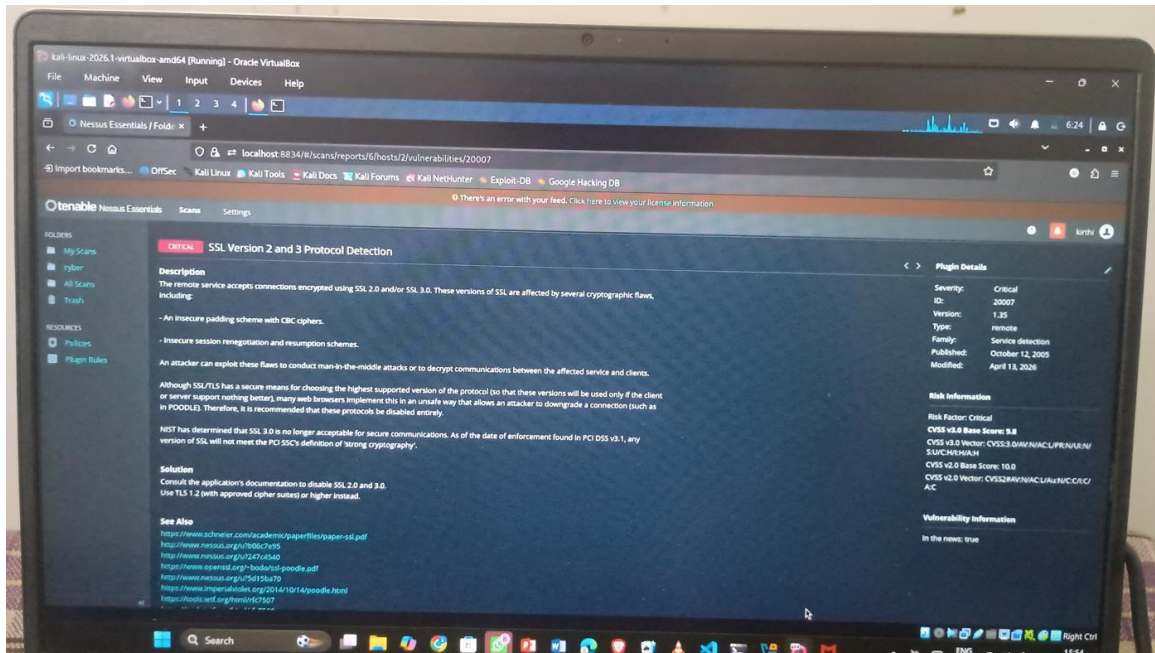
### A3. NFS Shares World Readable



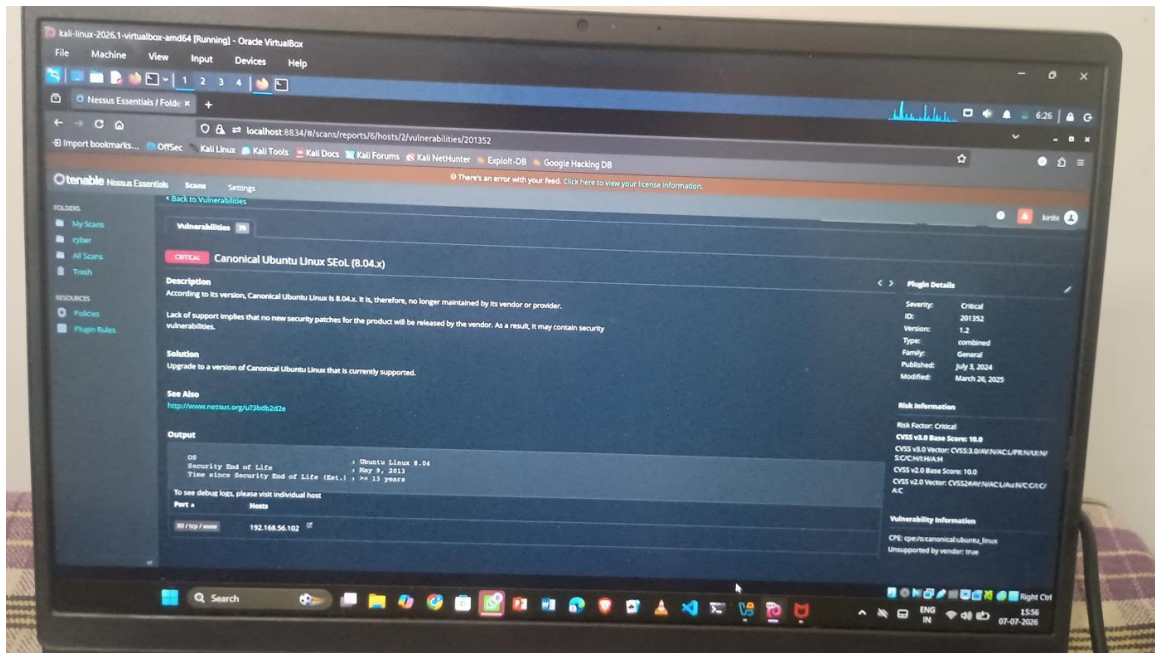
## A4. rlogin Service Detection — Exploit Available



## A5. SSL Version 2 and 3 Protocol Detection



## A6. Canonical Ubuntu Linux SEoL — 13+ Years Past End-of-Life



## A7. VNC Server Weak Password — Successfully Exploited by Nessus

